

Enhanced Attack Report

COLDSTEEL

Generated on 2025-10-09

Disclaimer

This report has been generated automatically and should be used for informational purposes only. To generate this report, Large Language Models (LLMs) were used to analyze the provided data. This technology is not perfect and may generate incorrect or misleading results. The results should be reviewed by a human expert before taking any action based on the information provided.

Definitions

Pre-Conditions: Conditions that must be true to execute the attack steps in the milestone.

Post-Conditions: Traces that an attacker leaves behind after executing the attack steps in the milestone.

Attack Steps: Steps that an attacker would take to achieve the goal of the milestone.

MITRE Technique: Techniques from the MITRE ATT&CK; framework that are relevant to the milestone.

STIX

Malware Name: COLDSTEEL

Malware Description: • COLDSTEEL provides interactive desktop & command line invocation, functionality including the ability to copy files, take screenshots and simulate user input. • COLDSTEEL persists as a Windows service. • COLDSTEEL communicates with the C2 server using a raw TCP connection.

Quick Overview

Milestone m1

a1. Exploit Public-Facing Application as used by the malware (T1190)

Milestone m2

a2. Command and Scripting Interpreter: Windows Command Shell as used by the malware (T1059.003)

a3. System Services: Service Execution as used by the malware (T1569.002)

Milestone m3

a4. Create or Modify System Process: Windows Service as used by the malware (T1543.003)

Milestone m4

a5. Obfuscated Files or Information: Software Packing as used by the malware (T1027)

a6. Modify Registry as used by the malware (T1112)

a7. Indicator Removal: File Deletion as used by the malware (T1070.010)

a8. Access Token Manipulation: Create Process with Token as used by the malware (T1134.002)

Milestone m5

a9. System Information Discovery as used by the malware (T1082)

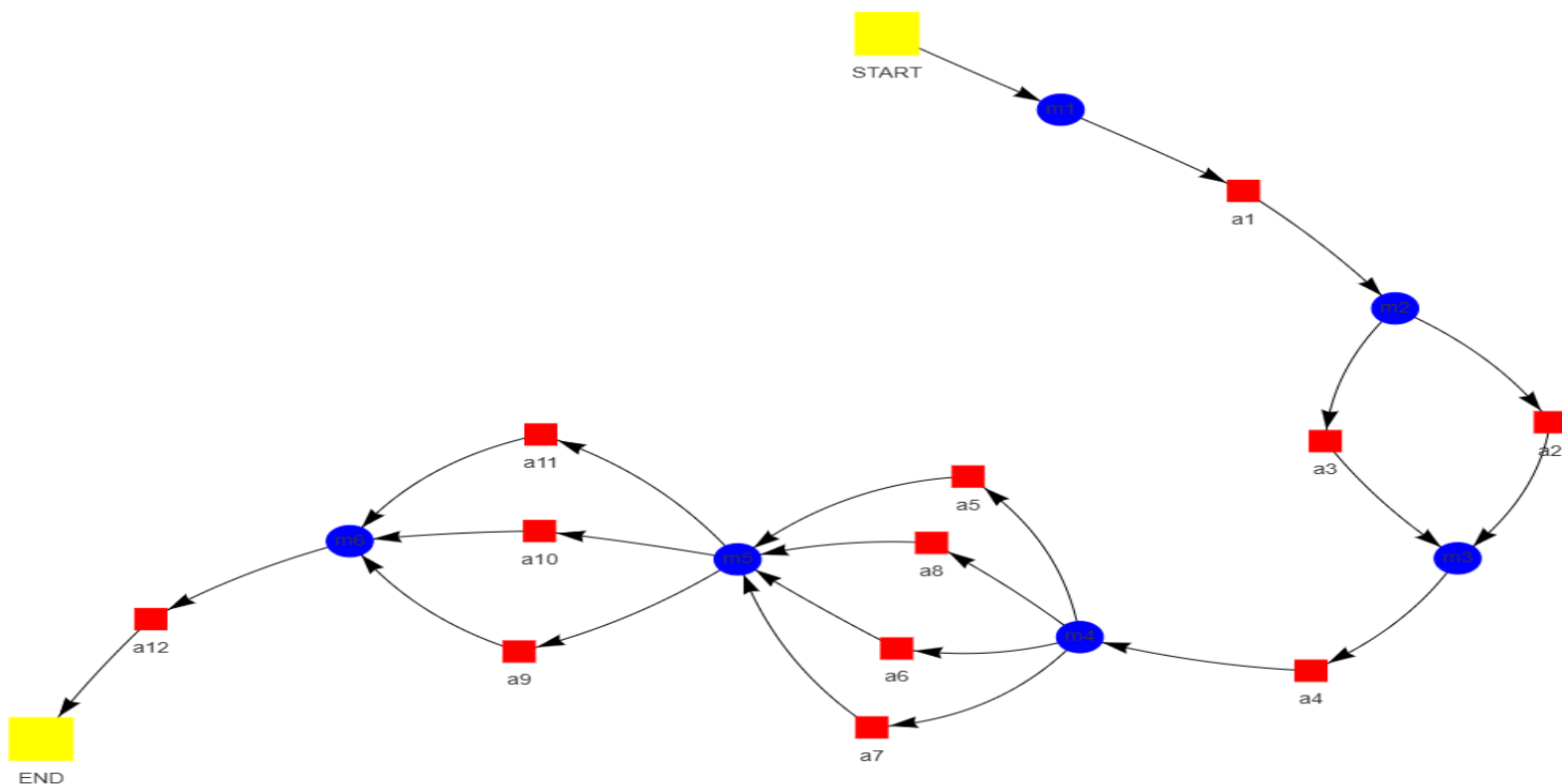
a10. File and Directory Discovery as used by the malware (T1083)

a11. Process Discovery as used by the malware (T1057)

Milestone m6

a12. Non-Application Layer Protocol as used by the malware (T1095)

Attack Graph



Milestone *m1*

Attack Step *a1*

=====

Name: Exploit Public-Facing Application as used by the malware

Description: The Fire Chili rootkit is characterized by a multi-stage infection process involving a dropper, a loader (newdev.dll), and a final payload (Milestone backdoor). Themida, a software packer designed to obfuscate code and hinder reverse engineering analysis, is utilized by the malware for protection. Network evasion techniques are employed by Fire Chili to conceal network connections from detection tools such as netstat through the interception and modification of system calls related to network information. The deployment of Fire Chili is believed to have been facilitated following the exploitation of the Log4j vulnerability (CVE-2021-44228). This critical vulnerability in the widely used Java logging library, Log4j, permitted attackers to execute arbitrary code on vulnerable systems through specially crafted input. Initial access to target systems is likely achieved by exploiting this Log4j vulnerability. Attackers would have sent malicious payloads disguised as legitimate data to servers running vulnerable Log4j applications.

Pre-Conditions:

- The malware has been deployed to a system with access to the internet.
- A vulnerable public-facing application exists.

Post-Conditions:

- Network traffic to C2 server (observed on firewall logs or network monitoring tools).
- Log entries indicating driver installation and service creation.
- Potential for further malicious activity on the compromised system.
- Altered system configuration settings.
- Deleted temporary files related to malware execution.
- Presence of unusual processes running with elevated privileges.
- Stolen credentials and sensitive information.
- Presence of malicious DLL files (e.g., newdev.dll, winmm.dll) in system directories.
- New user account created (potentially with unusual name).
- Compromised system with persistent backdoor access.
- Data exfiltration to C2 server.
- Modified registry entries related to services and drivers.

MITRE Technique

ID: T1190

Name: Exploit public-facing application

Description: Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration.

More info: <https://attack.mitre.org/techniques/T1190/>

Milestone *m2*

Attack Step a2

=====

Name: Command and Scripting Interpreter: Windows Command Shell as used by the malware

Description: The Windows Command Shell (cmd.exe) is frequently exploited by malware due to its capabilities for executing commands on a system. Malware often injects its own code into running cmd.exe processes or initiates new ones, enabling command execution without user interface interaction. Within cmd.exe, malware can execute valid Windows commands, encompassing file manipulation, system configuration alterations, network communication establishment, and process control functionalities. Obfuscation techniques are frequently employed by malware authors to conceal the commands sent to cmd.exe, hindering detection and analysis by security tools. System-level access granted to cmd.exe poses a significant security risk, enabling malware to make profound changes to a system. The stealthy nature of obfuscated commands can mask malicious activity from users and security tools. Furthermore, malware can leverage cmd.exe for lateral movement across networks.

Pre-Conditions:

- The malware has access to a Windows operating system.
- The malware has the capability to execute code.
- A Windows operating system is present.

Post-Conditions:

MITRE Technique

ID: T1059.003

Name: Command and scripting interpreter: windows command shell

Description: Adversaries may abuse the Windows command shell for execution. The Windows command shell (cmd) is the primary command prompt on Windows systems. The Windows command prompt can be used to control almost any aspect of a system, with various permission levels required for different subsets of commands. The command prompt can be invoked remotely via Remote Services such as SSH.

More info: <https://attack.mitre.org/techniques/T1059/003>

Attack Step a3

=====

Name: System Services: Service Execution as used by the malware

Description: The "COLD FIRE" malware exploits the System Services: Service Execution technique to achieve persistent and stealthy operation within compromised systems. A new Windows service is likely created by the malware, potentially employing a legitimate-sounding name to evade detection. Malicious code is then injected into this newly established service. Upon configuration, the service is automatically initiated and executed as a background process by the operating system. Due to the inherent trust bestowed upon services within the Windows architecture, they frequently operate with elevated privileges. This grants the injected malicious code increased control over the system

resources.

Pre-Conditions:

- A service is installed on the system.
- The malware has the ability to interact with the Windows Service Control Manager (SCM).

Post-Conditions:

- Compromised system with persistent malware.
- Hidden processes running with obfuscated names.
- Potential for further attacks and lateral movement within the network.
- Modified firewall rules allowing outbound communication to specific IPs.
- New user account created (e.g., "ANONYMOUS").
- Network connections to unknown C2 servers.
- Altered registry settings related to system services and network connections.
- System instability and performance degradation.
- New files dropped in various locations (e.g., "%APPDATA%\newdev.dll", "C:\Windows\system32\drivers\crtsys.sys").
- Log entries indicating suspicious activity and file modifications.
- Data exfiltration to C2 server.
- Modified system services (e.g., "msupdate", "msupdate2").

MITRE Technique

ID: T1569.002

Name: System services: service execution

Description: Adversaries may abuse the Windows service control manager to execute malicious commands or payloads. The Windows service control manager (services.exe) is an interface to manage and manipulate services. The service control manager is accessible to users via GUI components as well as system utilities such as sc.exe and Net.

More info: <https://attack.mitre.org/techniques/T1569/002>

Milestone *m3*

Attack Step *a4*

=====

Name: Create or Modify System Process: Windows Service as used by the malware

Description: The Fire Chili rootkit is characterized by its multifaceted capabilities designed to evade detection. Persistence is achieved through the creation of a Windows service designated as "msupdate2" or variations thereof, ensuring continuous operation even after system reboots. Process hiding techniques are employed to obscure malicious processes from standard monitoring tools such as Task Manager. This is accomplished by intercepting system calls related to process management and manipulating data structures to remove entries corresponding to malicious processes from viewable lists. Network connection obfuscation is achieved through the interception of network-related IOCTLs (Input/Output Control) sent to the system. Connections matching predefined criteria associated with the malware are filtered out, hindering detection by security tools. File system manipulation capabilities are attributed to the rootkit, although specific methods remain undisclosed. It is suggested that the rootkit may alter file attributes or content to evade detection by antivirus software. Technical details reveal the utilization of a dropper program that downloads and executes a loader module named "newdev.dll." This loader subsequently decrypts and loads a backdoor component known as "Milestone," which is based on the Gh0st RAT framework. Communication between the Milestone backdoor and a command-and-control (C2) server occurs uncompressed, differing from some other variants of Gh0st RAT. Analysis indicates the existence of diverse Fire Chili versions, including those derived from leaked Gh0st RAT source code. Potential links to the Deep Panda threat actor group are suggested due to similarities in employed techniques. The sophisticated nature of Fire Chili underscores the continuous evolution of malware tactics. Its ability to conceal processes, obfuscate network traffic, and establish persistent presence on infected systems presents significant challenges for detection and removal.

Pre-Conditions:

- The system has a running instance of the Windows operating system.
- The user account executing the process has sufficient privileges to create and modify system services.

Post-Conditions:

MITRE Technique

ID: T1543.003

Name: Create or modify system process: windows service

Description: Adversaries may create or modify Windows services to repeatedly execute malicious payloads as part of persistence. When Windows boots up, it starts programs or applications called services that perform background system functions. Windows service configuration information, including the file path to the service's executable or recovery programs/commands, is stored in the Windows Registry.

More info: <https://attack.mitre.org/techniques/T1543/003>

Milestone *m4*

Attack Step *a5*

=====

Name: Obfuscated Files or Information: Software Packing as used by the malware

Description: Software packing techniques, specifically employing Themida, are utilized by the Milestone2017 variants of COLDSTEEL malware to facilitate defense evasion. Themida, a commercial software protection tool, is frequently leveraged by malware authors due to its robust encryption algorithms, code virtualization capabilities, and integrated anti-debugging features. These attributes contribute to the obfuscation of malicious code, rendering it more difficult for security analysis tools to identify and interpret its functionality. The packing process involves the compilation of original COLDSTEEL source code, followed by input into Themida. Subsequently, encryption and compression are applied to the code, resulting in a significantly reduced and less readable form. The code's structure is also rewritten, introducing additional layers of complexity. A stub program is generated as part of this process. This stub functions as a loader, responsible for decrypting and decompressing the packed code upon malware execution. The application of Themida within COLDSTEEL (Milestone2017) presents significant challenges to security analysis efforts. The heavily encrypted and obfuscated nature of the packed code hinders the identification of malicious intent and functionality by researchers. Furthermore, traditional antivirus signatures, which often rely on recognizing specific code patterns, are rendered less effective due to the dynamic nature of packed code resulting from the packing process. The consequences of employing Themida in COLDSTEEL (Milestone2017) are substantial. The malware's ability to evade detection and analysis is significantly enhanced, enabling attackers to: - Spread undetected within systems, avoiding triggering alarms or raising suspicion. - Execute malicious activities once inside a system, such as data theft, installation of additional malware, or operational disruption.

Pre-Conditions:

- The malware code must be present.
- A target file or data set exists for packing.
- The malware is designed to obfuscate files or information.
- System resources are available for execution and processing.

Post-Conditions:

- Presence of malicious code in memory or on disk.
- Altered system event logs with suspicious activity.
- Compromised user accounts.
- Modified file timestamps and permissions.
- Data corruption or loss.
- Modified system registry entries.
- System instability or crashes.
- New files created in unexpected locations (e.g., %TEMP%, AppData).
- Malware infections.
- Unusual process activity (e.g., high CPU usage, unexpected program launches).
- Unusual network traffic logs (e.g., connections to unknown servers, excessive data transfer).
- Unauthorized access to sensitive information.
- Network vulnerabilities exploited.

MITRE Technique

ID: T1027

Name: Obfuscated files or information

Description: Adversaries may attempt to make an executable or file difficult to discover or analyze by encrypting, encoding, or otherwise obfuscating its contents on the system or in transit. This is common behavior that can be used across different platforms and the network to evade defenses.

More info: <https://attack.mitre.org/techniques/T1027/>

Attack Step a6

=====

Name: Modify Registry as used by the malware

Description: Registry key modifications are frequently employed by malware for several purposes. These modifications can be implemented to ensure persistence by enabling automatic execution upon system startup. Additionally, malware may alter file and process names or descriptions to evade detection. Malicious code can also be stored within registry values for subsequent execution. In specific instances, malware modifies registry keys directly to append a description to its service. This practice is likely undertaken for two primary reasons: disguise and evasion. By assigning a seemingly legitimate name or description to its service, malware attempts to assimilate with other system services and minimize suspicion. Furthermore, modifying the description may assist malware in evading detection by security tools that scrutinize unusual or suspicious registry changes. Registry modifications constitute a prevalent tactic utilized by malware, presenting significant challenges for detection and removal. The inherent nature of the registry, as the central component of Windows governing numerous system settings and processes, grants malware with extensive access upon modification. Malicious alterations can be subtle and difficult to discern without specialized tools. Moreover, persistence is often ensured through registry modifications, enabling malware to continue operation even after system restarts. To mitigate the risks associated with malware that modifies the registry, several protective measures can be implemented. Maintaining an updated system is crucial as security updates frequently address vulnerabilities exploited by malware. Employing robust antivirus software capable of detecting and removing malware, including those targeting the registry, is essential. Exercise caution when downloading software, ensuring it originates from trusted sources. Regularly backing up data provides a safeguard against potential malware infection, enabling system restoration if necessary.

Pre-Conditions:

- The malware has successfully executed within the target system.
- A running Windows operating system is present.
- The malware executable is loaded into memory.
- The malware possesses necessary permissions to modify registry keys.

Post-Conditions:

- XOR-encrypted and LZMA-compressed files
- Data exfiltration possible
- Log entries related to service installation and process manipulation
- Modified system services
- Altered file system entries
- Hidden processes in ActiveProcessLinks list
- Network connections to C2 server
- System compromised

- Persistence established
- New driver installed ("FSFilter-Min")
- Modified registry keys
- Remote control over infected system

MITRE Technique

ID: T1112

Name: Modify registry

Description: Adversaries may interact with the Windows Registry as part of a variety of other techniques to aid in defense evasion, persistence, and execution.

More info: <https://attack.mitre.org/techniques/T1112/>

Attack Step a7

=====

Name: Indicator Removal: File Deletion as used by the malware

Description: File deletion is a capability exhibited by the COLDSTEEL malware. The precise mechanism employed for file deletion remains unspecified; however, inferences can be drawn regarding its potential methodologies. Direct file system manipulation through system calls or API functions is a plausible method. Such functions could include DeleteFile or analogous operations contingent upon the operating system in use. Alternatively, scripting languages such as PowerShell might be leveraged by COLDSTEEL to execute commands for file deletion. This approach could facilitate more intricate scenarios, encompassing the deletion of files based on predefined patterns or criteria. Indicators of Compromise (IOCs) associated with this capability include the presence of specific deleted filenames, such as "1.bat", "syn.exe", and "1.dll". Furthermore, system logs may contain entries documenting file deletion events, potentially correlating timestamps and process names to COLDSTEEL activity. Mitigation strategies encompass the implementation of regular data backups to facilitate recovery even in the event of malicious file deletion. Robust antivirus and endpoint security solutions can contribute to the detection and prevention of such activities. User education programs aimed at fostering awareness regarding suspicious files and links can serve to reduce the risk of infection.

Pre-Conditions:

- The malware is running in an environment with a file system.

Post-Conditions:

- New user account "ANONYMOUS" created with password "MileStOne2@16".
- Potential for further malicious activity on the compromised system.
- Modified registry entries related to Windows services.
- Unusual process activity and resource usage patterns.
- Network connections to C2 server established and logged.
- Loss of system integrity and confidentiality.
- Compromised system with persistent backdoor access.
- Modified file timestamps and access logs.
- Data exfiltration to C2 server.
- Presence of malicious files (backdoor, dropper) in various locations on the system.

MITRE Technique

ID: T1070.010

Name: Indicator removal: relocate malware

Description: Once a payload is delivered, adversaries may reproduce copies of the same malware on the victim system to remove evidence of their presence and/or avoid defenses. Copying malware payloads to new locations may also be combined with File Deletion to cleanup older artifacts.

More info: <https://attack.mitre.org/techniques/T1070/010>

Attack Step a8

=====

Name: Access Token Manipulation: Create Process with Token as used by the malware

Description: The MileStone2016 malware variant leverages the Windows API function CreateProcessAsUser to instantiate a new process inheriting the security context of the "ANONYMOUS" user account. This process is executed with the privileges and permissions associated with the specified access token.

Pre-Conditions:

- A running operating system with appropriate kernel functionality.
- The malware possesses the necessary code to manipulate access tokens.
- The malware has successfully infected a target system.
- The malware has the capability to read and modify memory.

Post-Conditions:

- C2 server communication logs
- Disruption of services
- New user accounts created
- Data transfer logs
- Backdoor executables
- Registry key changes
- Hidden files and folders
- System compromise
- Data exfiltration
- Altered process lists
- Modified system files
- Lateral movement within the network
- Loss of data integrity
- Execution of malicious code
- Installation of persistent backdoors
- Unusual network traffic logs

MITRE Technique

ID: T1134.002

Name: Access token manipulation: create process with token

Description: Adversaries may create a new process with an existing token to escalate privileges and bypass access controls. Processes can be created with the token and resulting security context of another user using features such as CreateProcessWithTokenW and runas.

More info: <https://attack.mitre.org/techniques/T1134/002>

Milestone *m5*

Attack Step *a9*

=====

Name: System Information Discovery as used by the malware

Description: System information discovery techniques employed by the COLDSTEEL malware are inferred through analysis of common methodologies utilized by similar malicious software. These techniques may include direct API calls to retrieve system-level data such as computer name, operating system details, processor architecture, memory availability, and process information. Furthermore, COLDSTEEL is likely to conduct registry scans to extract user account credentials, installed software inventories, network configurations, and system settings. Network information, including interface details, IP addresses, and MAC addresses, may be gathered using APIs such as GetAdaptersInfo. File system access could enable the malware to identify sensitive documents, configuration files, and logs containing valuable data. The specific techniques employed by COLDSTEEL may exhibit variations contingent upon its objectives and the characteristics of the target environment.

Pre-Conditions:

- The malware is running.
- The system has network connectivity.

Post-Conditions:

- Modified system configurations related to security settings and permissions.
- Encrypted communication logs between compromised systems and C2 servers.
- New files with malicious code (backdoor, dropper) in system directories.
- Modified registry entries related to services and processes.
- Unusual network connections to command-and-control servers.
- Log entries indicating suspicious process activity and file modifications.
- Compromised systems with persistent backdoor access.
- System instability and performance degradation.
- Increased risk of further attacks and malware infections.
- Potential for lateral movement within the victim's network.
- Data exfiltration from compromised systems.

MITRE Technique

ID: T1082

Name: System information discovery

Description: An adversary may attempt to get detailed information about the operating system and hardware, including version, patches, hotfixes, service packs, and architecture. Adversaries may use the information from System Information Discovery during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

More info: <https://attack.mitre.org/techniques/T1082/>

Attack Step *a10*

=====

Name: File and Directory Discovery as used by the malware

Description: File and directory discovery capabilities exhibited by COLDSTEEL malware are inferred through analysis of its observed behaviors. Registry key modifications, potentially indicative of attempts to conceal presence or manipulate system behavior, are noted. Utilization of a command-line interface suggests the employment of standard operating system utilities such as "dir" or "ls" for listing files and directories within specified paths. The presence of dedicated threads for process interaction and file handling implies the existence of custom code modules potentially designed to interact with the filesystem in a manner that circumvents standard operating system calls, thereby enabling more covert operations. Network communication via raw TCP connections to a Command and Control (C2) server suggests the possibility of exfiltrating gathered file and directory information. The application of obfuscation techniques complicates the precise determination of COLDSTEEL's file discovery methodologies.

Pre-Conditions:

- The target system has files and directories present.
- The malware is running within a target system.
- A running instance of the COLDSTEEL malware.

Post-Conditions:

- Modified system configuration files
- Altered system logs
- Modified system registry entries
- Potential for further malware infections
- New user accounts created
- System instability and performance degradation
- Backdoor executable files
- Hidden files and folders
- Compromised system integrity
- Data exfiltration
- Unusual process activity
- Loss of system control
- Network connections to malicious C2 servers

MITRE Technique

ID: T1083

Name: File and directory discovery

Description: Adversaries may enumerate files and directories or may search in specific locations of a host or network share for certain information within a file system. Adversaries may use the information from File and Directory Discovery during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

More info: <https://attack.mitre.org/techniques/T1083/>

Attack Step a11

=====

Name: Process Discovery as used by the malware

Description: Process information is collected by the FBI20111024 malware variant through the exploitation of system calls and API functions inherent to the Windows operating system. System calls, such as EnumProcesses, are potentially leveraged to retrieve a comprehensive list of active processes, encompassing process identifiers (Process IDs), names, and pertinent supplementary information. Alternatively, or concurrently, Windows API functions, including CreateToolhelp32Snapshot, Process32First, and Process32Next, may be utilized to enumerate processes in a structured manner, facilitating access to process details within the operating system's memory space. Upon acquisition of process information, it is likely stored within internal malware structures for subsequent analysis or transmission to a command-and-control (C2) server.

Pre-Conditions:

- The malware possesses the capability to interact with the operating system's process information.
- The malware is running within a target system.
- Network connectivity may be required for communication with a command and control server.
- The target system has processes executing.

Post-Conditions:

- Network access established for attacker
- System files modified
- Hidden files and folders containing malware or stolen data
- New user accounts created with unusual names or permissions
- Network traffic logs revealing communication with external IP addresses associated with the attacker
- User account compromised
- Sensitive data exfiltrated
- Log entries showing unauthorized access attempts and successful logins
- Altered system configurations indicating changes to security settings
- Registry keys altered

MITRE Technique

ID: T1057

Name: Process discovery

Description: Adversaries may attempt to get information about running processes on a system. Information obtained could be used to gain an understanding of common software/applications running on systems within the network. Administrator or otherwise elevated access may provide better process details. Adversaries may use the information from Process Discovery during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

More info: <https://attack.mitre.org/techniques/T1057/>

Milestone *m6*

Attack Step *a12*

=====

Name: Non-Application Layer Protocol as used by the malware

Description: COLDSTEEL utilizes the Transmission Control Protocol (TCP) for communication with its command-and-control (C2) server. A TCP socket is established on the infected machine to facilitate this interaction. Connection establishment involves a SYN packet sent by COLDSTEEL to the C2 server, followed by a SYN-ACK response from the server. Data exchange occurs through custom messages transmitted over the established TCP connection. The structure of these messages typically comprises a header and a payload. The header contains a command ID, indicating the type of command being executed, and a message length field specifying the total message size. A parameter field may be present for future extensions or variations in command execution. The payload carries the data associated with the command, which can include system information, file paths, or command arguments. To hinder detection, COLDSTEEL likely employs obfuscation and encryption techniques such as XOR encryption using a shared secret key and encoding schemes like base64.

Pre-Conditions:

- A system infected with the malware.
- Network connectivity to the command and control server.

Post-Conditions:

- Altered file permissions
- Unauthorized access to sensitive information
- Obfuscated communication logs
- Backdoor executable files
- Suspicious entries in event logs
- Compromised user accounts
- System instability
- Deleted or modified log files
- New system services
- Malware infection
- Presence of malicious code in memory
- Modified registry keys
- Network intrusion
- Data loss
- Unusual network traffic logs
- Hidden processes in task manager

MITRE Technique

ID: T1095

Name: Non-application layer protocol

Description: Adversaries may use an OSI non-application layer protocol for communication between host and C2 server or among infected hosts within a network. The list of possible protocols is extensive. Specific examples include use of network layer protocols, such as the Internet Control Message Protocol (ICMP), transport layer protocols, such as the User Datagram Protocol (UDP), session layer

protocols, such as Socket Secure (SOCKS), as well as redirected/tunneled protocols, such as Serial over LAN (SOL).

More info: <https://attack.mitre.org/techniques/T1095/>